SPECS · CHALLENGE & SOLUTION · #CRAG · #LORA · #HUMANINTHELOOP · #ADK · #HELM · #SOC2 · #AGENTICCOMMERCE

The AI ladder: retrieval, adapters, humans, and who holds the keys

Knowledge Base

0. Vocabulary

Four readers use these words — a business analyst, a developer, a compliance reviewer and a designer — and several of them are used loosely elsewhere. This document uses them this way.

TERM	MEANS HERE	DOES NOT MEAN
RAG — retrieval-augmented generation	The model answers from passages retrieved at question time (here: a vector index of FAQs, articles, manuals)	Training. Nothing about the model changes
CRAG — *Corrective* RAG (Yan et al., 2024)	RAG with a **grader between retrieval and answer**: passages judged correct → used; incorrect → discarded and another source tried; ambiguous → both	A different retriever. It is a gate on whatever the retriever returns
CRAG (benchmark)	Meta's Comprehensive RAG Benchmark (KDD Cup 2024) — a test set	The technique above. Check which one is meant
LoRA — Low-Rank Adaptation (Hu et al., 2021)	Base model frozen; small low-rank matrices trained beside chosen layers (well under 1 % of parameters); shipped as a swappable **adapter** of megabytes. **QLoRA** is the same on a compressed base	A full fine-tune, or a way to add facts
Human-in-the-loop escalation	A question the system cannot answer well enough is routed to a person, on a clock set by its urgency, and the person's answer is kept	A "contact us" link. An escalation has a tier, a deadline and a record
Permission	What an *application* may reach	What a person may do
Entitlement	What a *subject* may do (a capability row, revocable)	A role name
Mandate	What an *agent* may do **on someone's behalf**: signed, capped, scoped, time-boxed, revocable	A stored password or API key
ADK — Google Agent Development Kit	A runtime for LLM **agents**: sub-agents, tools, sessions, memory	Infrastructure. It decides what to *try*, not what is *allowed*
Kubernetes / Helm	Kubernetes runs containers; **Helm** packages them: a *chart* (templates) + a *values* file per deployment	A security boundary for data. It places workloads

TERM	MEANS HERE	DOES NOT MEAN
SOC 2 review	A **procedural assessment**: an independent CPA firm examines how an organisation runs a service — people, process and technology, end to end — against the AICPA **Trust Services Criteria**, and issues a **report** with its opinion and any exceptions. **Type I** tests whether controls are *designed* properly at one date; **Type II** tests whether they *operated* effectively over a period (commonly 3–12 months)	A certification, a certificate, a badge on a product, a database, a tool you install, or a law. There is no "SOC 2 certified" object — there is a report about an organisation's methods, for a period, with a scope
Trust Services Criteria	The five categories a SOC 2 report can cover: **Security** (always), **Availability**, **Processing Integrity**, **Confidentiality**, **Privacy**	A checklist of products. The organisation chooses which categories are in scope and designs its own controls against them
Helmet	This estate's name for a **higher-order function** at the Cloudflare edge: it takes the page's behaviour (or an agent's tool call) and returns a wrapped version that loads consent first and checks the mandate before anything acts	Helm. The name is borrowed on purpose — chart ≈ loader, values ≈ per-tenant config — but it runs on every request, not once at deploy

1. The challenge

What goes wrong, described by what it looks like from outside:

FAILURE	WHAT THE CUSTOMER SEES	WHY IT HAPPENS
Confident wrong answer	A fluent reply that cites the wrong product or an old policy	Plain RAG answers from whatever it retrieved, relevant or not
Stale fact in the weights	Last month's price, stated as fact, with no source to check	A fact was trained into a model, where it cannot be corrected or cited
The question nobody owns	"Sorry, I can't help with that" — and nothing happens next	No path from a failed answer to a person, and no record that it failed
An agent with standing credentials	A purchase nobody approved, or one over budget	The agent held a key instead of asking for permission per action
Two languages, one answer	The Korean page is right, the English one is not (or the reverse)	Answers maintained per language drift apart
Configuration that is really code	A new market deploys and asks the wrong consent questions	Where data lives was a constant in code, not a setting of the deployment

2. The solution: climb only when the data says so

RUNG	CHANGES	USE IT FOR	CLIMB WHEN…	WHAT IT GIVES UP
1. Instructions + claims	The prompt and the subject's claims (language, market, consent)	Tone, rules, language	Answers lack **facts** the model cannot know	Nothing — this is the floor
2. RAG	What the model **reads**	**Facts that change**: prices, stock, policy, FAQs, specs, legal text — per tenant, bilingual, citable	Retrieval returns the **right** passages but answers are still wrong in **how** they are written	A search index to maintain
2b. CRAG gate	Whether retrieved passages are **trusted**	Refusing a weak match, trying the next source, or escalating	— (it belongs on every RAG path)	Some questions are answered "I don't know" instead of guessed
3. LoRA adapter	How the model **writes**	Behaviour: tone, domain vocabulary, a fixed format, classifying a question	One adapter cannot hold the behaviours needed	Training data, an evaluation set, an adapter per tenant
4. Full fine-tune	The whole model	Rarely justified in commerce	—	Cost, and every fact baked in goes stale

The rule that does not bend: anything that changes stays at rung 2. A price trained into weights is wrong the day it changes and cannot be cited when a customer disputes it.

When is the data ready for rung 3? Not by volume — by measurement:

1. **An evaluation set first.** Real questions with accepted answers, in each language served. Without one, "the model got worse" and "the model got better" are both guesses.

2. **The evaluation shows retrieval is right and the writing is wrong.** That is the only signal a LoRA adapter can fix.
3. **Hundreds to low thousands of clean question → accepted-answer pairs** for *one* behaviour. Consistency beats size. (A rule of thumb, not a measured threshold.)

---

3. CRAG as it is actually built

The corrective gate is not new here; each surface already refuses weak answers before it writes one.

SURFACE	GRADER	BELOW THE BAR
Commerce FAQ answer: curated FAQs	Word match ≥ **0.8**, and the FAQ's question or keywords must hold at least **60 %** of the question's content words, in the question's language	Falls through to the next source
Commerce FAQ answer: knowledge base	The model writes the answer **only** from the retrieved passages, and replies `NOT_IN_DOCS` when they do not answer	Steps aside for the next source (a web lookup of the brand's own blog, then the store's data where the caller is entitled), then a person (§4)
Ask-the-Docs	Vector similarity ≥ **0.45**, and the same `NOT_IN_DOCS` check on the written answer	Returns links to the nearest documents, never a written guess
Bilingual product FAQ (floor heating)	Retrieval score ≥ **0.5**	Escalates to a person (§4)

Language is a route, not a weight. A question in Korean, Japanese or Chinese is matched against content in its own language first. Only when nothing clears the bar does it fall back to English, and the answer then says so in the asker's

language. Scores are never blended across languages: a strong English match must not outrank a weaker Korean one that answers in the shopper's language.

What it costs: a strict gate says "I don't know" more often. That is the correct trade in commerce, and it is also the input the next section depends on.

---

4. Human-in-the-loop escalation

A refused answer is not an ending. It becomes an escalation with a tier, a clock and a record.

TIER	MEANING	WHO ANSWERS, HOW FAST
none	Answered from the knowledge base	—
tier 1	Must be answerable **without** a person	Automated — because the Korean team's office hours are 19:00–04:00 US Eastern, a US-morning question cannot wait for them
tier 2	Needs a person, not urgent	Next business window
tier 3	Safety or legal	Immediately. A product-safety report is a compliance event: the US CPSC §15(b) clock runs **24 hours**

Design rules that make escalation useful, not just polite:

RULE	WHY
The escalation record accepts no name, email or phone	A question is training data; a person is a data subject. Mixing them gives the training set a retention clock and a deletion obligation
An answer counts as done only when it exists in both languages	Derived by the server (`pair_status`), never asserted by the caller — the invariant the log exists to protect
Keep what the knowledge base returned, even when wrong	The wrong retrievals are how gaps are found
A safety report can arrive through any form	Someone whose floor is smoking types it into whatever box is in front of them; the form path flags it too

Why this feeds the ladder: every escalation is a question the knowledge base could not answer, paired with the answer a person gave — in both languages. That is the curated, personal-data-free dataset rung 3 needs. The humans are not a fallback for the AI; they are where its next training set comes from.

---

5. ADK vs Kubernetes/Helm vs the Cloudflare helmet

Three layers that are often confused because each "runs" something.

	GOOGLE ADK	KUBERNETES + HELM	CLOUDFLARE HELMET (HIGHER-ORDER FUNCTION)
What it runs	An AI agent: which tool to call next	Containers: a model server, a gateway, a database	Every page load and every agent tool call at the edge
When it acts	During a conversation	At deploy time (Helm renders once)	**On every request**
Its "config"	Agent definitions, session state	A chart + a `values` file per deployment	A loader + per-tenant config (`/stack/config`) — the values file of a web page
What it decides	**What to try**	**Where workloads run**	**Whether an action may proceed** — consent first, then the mandate
Rollback	Redeploy the agent	One command, with release history	Only via a worker deploy — per-tenant promote/rollback is **not built**
Needed by every client?	**No** — optional (Google-side agents, BigQuery insights, A2A)	Only where a tenant self-hosts (e.g. a database in-country)	**Yes** — it is where permission is enforced

The equivalence that holds: an endpoint with permission checks in its function stack is an ADK **tool** with a guard — not an ADK **agent**. The agent is the layer that chooses which tools to call. Because the permission lives in the endpoint, the agent is swappable: ADK, an edge model, or a database vendor's own agent can sit on top, and none of them can do more than the endpoint allows.

Names are part of the contract. A swappable agent only helps if the tools it calls are named and shaped the way agents already expect. Google publishes its API design rules as API Improvement Proposals: resources addressed by hierarchical names (`accounts/{account}/products/{product}` , AIP-122), a small set of standard methods, and standard paging and errors. The merchant catalog tools here copy the names and shapes of Google's Merchant API, so an agent built against Google's own tools reads this catalog without remapping. Following the naming rules does not grant anything: the endpoint still decides.

Helm and the helmet share a shape, not a job. Both are *one template, different values per tenant*. Helm places a model server in Seoul or Iowa; the helmet decides, on the request, that a Korean visitor must grant an itemised cross-border consent before anything is stored — and that decision itself depends on a value (where this deployment keeps personal data), because a Seoul deployment must *not* ask it.

---

6. Mandates: the only way an agent acts

The helmet wraps every agent action in the same check. The agent brings a **mandate**, never a key.

PROPERTY	WHAT IT ENFORCES	CHECKED WHERE
Signed	Issued by the platform for this subject; forged mandates fail verification	Server, and verifiable offline with the public key
Capped	A maximum amount — checked on the **discounted** total, so a discount cannot be used to slip under it	Server, at checkout
Scoped	Which rails and markets it covers (e.g. a Korean settlement requires a sovereign-settlement capability)	Server, before any draft order exists
Time-boxed	Expires (default 24 hours)	Server
Revocable	One row change; takes effect on the next call	Server — entitlements are resolved per request, never frozen into a token
Consent-bound	Requires the subject's agent-purchase consent	Server

Why a higher-order function and not a check inside each tool: a check written into each tool is a check someone can forget in the next tool. A function that *wraps* every tool call — takes the action and returns the guarded action — is

written once, and a new tool is guarded by construction. It is the same reason consent loads first on every page rather than per feature.

What an agent never holds: a payment card (payment finishes on the processor's hosted page), a standing API key, or the shopper's login beyond the single step it was handed for.

---

7. SOC 2: what AI transport puts in scope

What a SOC 2 review is, precisely. It is a *360° procedural assessment*: not of a product, a server or a database, but of **how an organisation operates a system** — who can reach data, how changes are approved and tested, how vendors are chosen and watched, how incidents are detected and answered, how data is kept and destroyed. An independent CPA firm tests those methods against the Trust Services Criteria and writes a report. The report describes a **scope** (which system, which criteria) and a **period**; it can carry **exceptions** where a control did not work as described.

MISREADING	WHY IT IS WRONG	WHAT TO SAY INSTEAD
"Our product is SOC 2 certified"	SOC 2 is an attestation **report**, not a certification of an object	"Our operation of *system X* has a SOC 2 Type II report for *period Y*"
"The database is SOC 2"	A database is a component; the review covers the organisation's methods around it	"The provider of our database has its own SOC 2 report; we rely on it and cover our side"
"We use a SOC 2 vendor, so we are covered"	A vendor's report covers the vendor. Your controls over what you send it are yours — the report calls these **complementary user entity controls**	"We reviewed the vendor's report and operate the controls it assigns to us"
"Passed once, done"	Type II describes a period that ends; the next period is tested again	"Current report covers *dates*; the next period is in progress"

Where the fines actually come from. A SOC 2 report does not fine anyone. Penalties come from the **laws and contracts** the controls exist to satisfy — US state privacy law (for example California's CCPA/CPRA, assessed per violation), the GDPR in Europe, Korea's PIPA — and from customer contracts that require the controls. A report with exceptions is usually where that scrutiny starts: it is the document a customer, an auditor or a regulator reads first.

Why AI transport changes the scope. The moment an organisation's DevOps sends data to a model — a hosted LLM, an embedding service, an agent runtime, possibly in another country — new methods have to exist, and a reviewer will ask for evidence of each:

WHAT AI TRANSPORT ADDS	CRITERIA IT FALLS UNDER	THE EVIDENCE A REVIEWER ASKS FOR
A **new subprocessor** (the model provider) and possibly a new country	Security (vendor risk), Privacy (disclosure to third parties)	The subprocessor list, the provider's own report, where inference runs, whether it trains on your data
Personal data leaving the organisation in prompts, retrieval and memory	Confidentiality, Privacy	Minimisation (what is removed before sending), encryption in transit and at rest, consent for the purpose
Retention inside AI stores — vector indexes, agent memory, prompt logs	Confidentiality (disposal), Privacy (retention and deletion)	A retention period per store, and proof that an erasure request reaches each one
Changes to models, prompts and adapters	Security (change management)	Versioning, review, a test gate before release — a prompt change is a production change
An agent that can act (buy, refund, send)	Security (logical access), Processing Integrity	What authorises each action — here, a signed, capped, revocable mandate checked server-side — and a log of every grant and refusal
Answers customers rely on	Processing Integrity	How wrong answers are caught (§3), escalated (§4) and corrected

In this estate, the honest status: most of the evidence above exists as running code and records — field-level encryption before storage, a consent log per

grant, mandates checked on every action, retention and erasure jobs, a release gate. Two gaps are stated rather than hidden: agent-runtime sessions and memory are **not yet** in the erasure sweep, and the edge model used for public questions does **not** pin inference to one country. Mapping controls to the criteria is preparation for a review; it is not a SOC 2 report, and nothing here claims one.

8. What this costs

CHOICE	COST	STATED PLAINLY
CRAG gates	More "I don't know"	Correct in commerce, visible to customers
Escalation with tiers	People on a clock, in two languages	Tier 1 must be automatable because the humans are asleep for half the day
LoRA later, not now	Requires an evaluation set before any training	Slower to "AI-first" demos; faster to trustworthy ones
ADK optional	Google-specific features (Agent Engine memory, A2A) only where a tenant uses Google Cloud	Agent Engine sessions and memory are **not yet** covered by the erasure sweep — demo tenants only until they are
Edge models for public questions	Cloudflare Workers AI does not pin inference to one country	Fine for catalogue and FAQ; personal-data answers for Korea need a Korean-hosted model
The helmet	Runs on every request, so a bad config reaches visitors at once	Helm's one-command rollback is the property most worth borrowing, and it is not built

9. Summary

QUESTION	ANSWER
Where do facts go?	Retrieval (rung 2), behind a corrective gate
Where does behaviour go?	An adapter (rung 3) — only after an evaluation shows the need
What happens when neither is good enough?	A tiered escalation to a person, whose answer becomes the next training pair
Is ADK required?	No. It is one possible agent layer; permission does not live in it
What do Kubernetes/Helm do here?	Place workloads per deployment; the values file is where residency is declared
Is SOC 2 a certification?	No — a procedural assessment of how an organisation operates a system, reported for a scope and a period. AI transport adds subprocessors, retention stores, model changes and acting agents to what it must evidence
What stops an agent overreaching?	A signed, capped, scoped, time-boxed, revocable mandate — checked by the helmet on every action